FLOLIZ NIGERIA LIMITED
RC: 1574833

ADDRESS:
PLOT 54, CHOOS ESTATE,
WUMBA DISTRICT,
ABUJA FCT, NIGERIA.
TEL: +234-818 0640 370,
+234-703 7163 554.
Email: info@floliz.com.ng
Website: www.floliz.com.ng

14.03.2025

THE MANAGING DIRECTOR/CEO
MUTUAL TRUST MICROFINANCE BANK LIMITED

Dear Sir,

VULNERABILITY AND PENETRATION TEST REPORT

www.mutualtrustmfb.com

Sequel to the completion of the vulnerability and penetration test conducted on your web application we are pleased to submit the comprehensive vulnerability and penetration test report for your review and consideration.

At Floliz Nigeria Limited, we understand the critical importance of securing your digital infrastructure against potential threats and vulnerabilities. With this in mind, our team has meticulously conducted thorough assessments to identify any potential risks within your system.

The primary objective of our testing was to scrutinize your system's security measures and pinpoint any vulnerabilities or weaknesses that could potentially expose your organization to cyber threats. Our testing methodologies encompassed a wide array of techniques, including but not limited to penetration testing, vulnerability scanning, and risk analysis.

While your system demonstrates commendable resilience in many aspects, our report highlights certain vulnerabilities that could potentially compromise the integrity, confidentiality, and availability of your critical assets.

It is our sincere belief that proactive measures must be taken to address these identified vulnerabilities promptly. Our report provides detailed insights into each identified risk, along with recommendations and mitigation strategies tailored to your organization's specific needs and circumstances.

We urge you to review the report thoroughly and prioritize the implementation of recommended remediation measures. Our team remains committed to supporting you every step of the way, whether it involves further clarification on identified issues or assistance in implementing recommended solutions.

Should you require any additional information or assistance, please do not hesitate to contact us. We are dedicated to ensuring the security and resilience of your digital infrastructure and look forward to partnering with you in fortifying your defenses against evolving cyber threats.

Thank you for entrusting Floliz Nigeria Limited with this critical assessment. We appreciate the opportunity to contribute to the safeguarding of your organization's digital assets.

Yours Faithfully,
For: **Floliz Nigeria Limited**

Visionary & Innovation Officer
Name: **Daniel Uba**
Phone No**: 07045150430, 09099425904, 08180640370,**
Email Address: **info@floliz.com**

SUMMARY OF REPORT

S/N	VULNERABILITY IDENTIFIED	RISK RATING	APPENDIX PAGE REFERENCE
1	SSL/TLS: BEAST VULNERABILITY FOUND PORT 443/TCP	MEDIUM	APPENDIX 9
2	FTP SERVICE EXPOSED TO THE INTERNET PORT 21/TCP	LOW	APPENDIX 1
3	SPF RECORD: SOFT-FAIL ~ALL CONFIGURATION	LOW	APPENDIX 1

Network Vulnerability Scanner Report

✔ **www.mutualtrustmfb.com**

Summary

Overall risk level:

Low

Risk ratings:

Critical:	0
High:	0
Medium:	0
Low:	2
Info:	30

Scan information:

Start time:	Mar 10, 2025 / 23:08:10 UTC+02
Finish time:	Mar 10, 2025 / 23:43:37 UTC+02
Scan duration:	35 min, 27 sec
Tests performed:	32/32
Scan status:	Finished

Findings

FTP service exposed to the Internet

CONFIRMED

port 21/tcp

We managed to detect a publicly accessible File Transfer Protocol (FTP) service.

```
PORT STATE SERVICE VERSION
21/tcp open ftp Pure-FTPd
```

Details

Vulnerability description:

We found that the File Transfer Protocol (FTP) service is publicly accessible. The FTP enables client systems to connect to upload and download files. Nonetheless, FTP lacks encryption for the data exchanged between the server and the client, leaving all transferred data exposed in plaintext.

Risk description:

Exposing this service online can enable attackers to execute man-in-the-middle attacks, capturing sensitive user credentials and the contents of files because FTP operates without encryption. The entirety of the communication between the client and the server remains unsecured in plaintext. This acquired information could further facilitate additional attacks within the network.

Recommendation:

We recommend turning off FTP access over the Internet and instead using a Virtual Private Network (VPN) that mandates two-factor authentication (2FA). If the FTP service is essential for business purposes, we recommend limiting access only from designated IP addresses using a firewall. Furthermore, utilizing SFTP (Secure File Transfer Protocol) is recommended as this protocol employs encryption to secure data transfers.

SPF record: Soft-fail ~all configuration

CONFIRMED

Domain Queried	DNS Record Type	Description	Value
www.mutualtrustmfb.com	SPF	Sender Policy Framework	"v=spf1 ip4:192.64.117.151 ip4:192.64.117.153 include:spf.web-hosting.com ip4:192.64.117.156 +a +mx +ip4:92.205.10.197 include:secureserver.net +ip4:92.205.6.145 +ip4:160.153.146.49 +ip4:160.153.128.24 ~all"

Details

Vulnerability description:

We found that the Sender Policy Framework (SPF) record for the domain is configured with ~all (soft fail), which indicates that emails from unauthorized IP addresses are not explicitly denied. Instead, the recipient mail server is instructed to treat these messages with suspicion but may still accept them. This configuration may not provide enough protection against email spoofing and unauthorized email delivery, leaving the domain more vulnerable to impersonation attempts.

Risk description:

The ~all directive in an SPF record allows unauthorized emails to pass through some email servers, even though they fail SPF verification. While such emails may be marked as suspicious or placed into a spam folder, not all mail servers handle soft fail conditions consistently. This creates a risk that malicious actors can spoof the domain to send phishing emails or other fraudulent communications, potentially causing damage to the organization's reputation and leading to successful social engineering attacks.

Recommendation:

We recommend changing the SPF record's ~all (soft fail) directive to -all (hard fail). The -all setting tells recipient mail servers to reject emails from any IP addresses not listed in the SPF record, providing stronger protection against email spoofing. Ensure that all legitimate IP addresses and services that send emails on behalf of your domain are properly included in the SPF record before implementing this change.

IP Information

CONFIRMED

IP Address	Hostname	Location	Autonomous system (AS) Information	Organization (Name & Type)
192.64.117.153	www.mutualtrustmfb.com	United States	Namecheap Inc (AS22612)	PNAP PHX (business)

Details

Risk description:

If an attacker knows the physical location of an organization's IP address and its Autonomous System (AS) number, they could launch targeted physical or cyber attacks, exploiting regional vulnerabilities or disrupting critical infrastructure.

Recommendation:

We recommend reviewing physical security measures and monitoring network traffic for unusual activity, indicating potential cyber threats. Additionally, implementing robust network segmentation and adopting encryption protocols for data in transit can help protect sensitive information, even if attackers are aware of the IP addresses and the Autonomous System (AS) number.

DNS Records

port 53/udp

CONFIRMED

Domain Queried	DNS Record Type	Description	Value
www.mutualtrustmfb.com	A	IPv4 address	192.64.117.153
www.mutualtrustmfb.com	NS	Name server	dns1.namecheaphosting.com
www.mutualtrustmfb.com	NS	Name server	dns2.namecheaphosting.com
www.mutualtrustmfb.com	MX	Mail server	50 mx3.zoho.com
www.mutualtrustmfb.com	MX	Mail server	20 mx2.zoho.com
www.mutualtrustmfb.com	MX	Mail server	10 mx.zoho.com
www.mutualtrustmfb.com	SOA	Start of Authority	dns1.namecheaphosting.com. cpanel.tech.namecheap.com. 1736950690 86400 7200 3600000 86400
www.mutualtrustmfb.com	TXT	Text record	"zoho-verification=zb14573465.zmverify.zoho.com"
www.mutualtrustmfb.com	SPF	Sender Policy Framework	"v=spf1 ip4:192.64.117.151 ip4:192.64.117.153 include:spf.web-hosting.com ip4:192.64.117.156 +a +mx +ip4:92.205.10.197 include:secureserver.net +ip4:92.205.6.145 +ip4:160.153.146.49 +ip4:160.153.128.24 ~all"
www.mutualtrustmfb.com	CNAME	Canonical name	mutualtrustmfb.com

Details

Risk description:

An initial step for an attacker aiming to learn about an organization involves conducting searches on its domain names to uncover DNS records associated with the organization. This strategy aims to amass comprehensive insights into the target domain, enabling the attacker to outline the organization's external digital landscape. This gathered intelligence may subsequently serve as a foundation for launching attacks, including those based on social engineering techniques. DNS records pointing to services or servers that are no longer in use can provide an attacker with an easy entry point into the network.

Recommendation:
We recommend reviewing all DNS records associated with the domain and identifying and removing unused or obsolete records.

Open ports discovery

CONFIRMED

Port	State	Service	Product	Product Version
21	open	ftp	Pure-FTPd	None
25	open	smtp	None	None
26	open	smtp	Exim smtpd	4.98.1
53	open	domain	None	None
80	open	http	None	None
110	open	pop3	Dovecot pop3d	None
143	open	imap	Dovecot imapd	None
443	open	https	None	None
587	open	smtp	Exim smtpd	4.98.1
993	open	imaps	None	None
995	open	pop3s	None	None
2077	open	http	None	None
2078	open	https	cPanel httpd	None
2079	open	http	None	None
2080	open	https	TwistedWeb httpd	9.0.0
2082	open	http	None	None
2083	open	https	None	None
2095	open	http	None	None
2096	open	https	None	None

Details

Risk description:
This is the list of ports that have been found on the target host. Having unnecessary open ports may expose the target to more risks because those network services and applications may contain vulnerabilities.

Recommendation:
We recommend reviewing the list of open ports and closing the ones which are not necessary for business purposes.

Web redirect detected on port 80

CONFIRMED

We managed to detect the redirect using the following Request / Response chain.
Details

Recommendation:
Vulnerability checks are skipped for ports that redirect to another port. We recommend scanning the redirected port directly.

Web redirect detected on port 2082

CONFIRMED

We managed to detect the redirect using the following Request / Response chain.
Details

Recommendation:
Vulnerability checks are skipped for ports that redirect to another port. We recommend scanning the redirected port directly.

Web redirect detected on port 2095

CONFIRMED

We managed to detect the redirect using the following Request / Response chain.

Details

Recommendation:
Vulnerability checks are skipped for ports that redirect to another port. We recommend scanning the redirected port directly.

Server software and technologies

port 443/tcp

UNCONFIRMED

Software / Version	Category
WOW	JavaScript frameworks, Web frameworks, JavaScript graphics
Bootstrap	UI frameworks
React	JavaScript frameworks
Gatsby 4.25.9	Static site generator, JavaScript frameworks
LiteSpeed	Web servers
Mixitup	JavaScript libraries
Dashly	Marketing automation
Sectigo	SSL/TLS certificate authorities
Webpack	Miscellaneous

Details

Vulnerability description:
We noticed that server software and technology details are exposed, potentially aiding attackers in tailoring specific exploits against identified systems and versions.

Risk description:
The risk is that an attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:
We recommend you to eliminate the information which permits the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

Server software and technologies

port 2077/tcp

UNCONFIRMED

Software / Version	Category
Sectigo	SSL/TLS certificate authorities
Basic	Security

Details

Vulnerability description:
We noticed that server software and technology details are exposed, potentially aiding attackers in tailoring specific exploits against identified systems and versions.

Risk description:
The risk is that an attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:
We recommend you to eliminate the information which permits the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

Server software and technologies
port 2078/tcp

UNCONFIRMED

Software / Version	Category
Sectigo	SSL/TLS certificate authorities
Basic	Security

Details

Vulnerability description:
We noticed that server software and technology details are exposed, potentially aiding attackers in tailoring specific exploits against identified systems and versions.

Risk description:
The risk is that an attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:
We recommend you to eliminate the information which permits the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

Server software and technologies
port 2080/tcp

UNCONFIRMED

Software / Version	Category
TwistedWeb 9.0.0	Web servers
Sectigo	SSL/TLS certificate authorities
HSTS	Security
Basic	Security

Details

Vulnerability description:
We noticed that server software and technology details are exposed, potentially aiding attackers in tailoring specific exploits against identified systems and versions.

Risk description:
The risk is that an attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:
We recommend you to eliminate the information which permits the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

Server software and technologies
port 2083/tcp

UNCONFIRMED

Software / Version	Category
cPanel	Hosting panels
Sectigo	SSL/TLS certificate authorities

Details

Vulnerability description:
We noticed that server software and technology details are exposed, potentially aiding attackers in tailoring specific exploits against identified systems and versions.

Risk description:
The risk is that an attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:
We recommend you to eliminate the information which permits the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

Server software and technologies

port 2096/tcp

UNCONFIRMED

Software / Version	Category
Sectigo	SSL/TLS certificate authorities

Details

Vulnerability description:
We noticed that server software and technology details are exposed, potentially aiding attackers in tailoring specific exploits against identified systems and versions.

Risk description:
The risk is that an attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:
We recommend you to eliminate the information which permits the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

OS detection couldn't determine the operating system.

Domain name servers are not vulnerable to DNS Server Zone Transfer Information Disclosure (AXFR) vulnerability

Version-based detection found no vulnerabilities on port 21

port 21/tcp

Version-based detection found no vulnerabilities on port 25

port 25/tcp

Version-based detection found no vulnerabilities for Exim smtpd 4.98.1

port 26/tcp

Version-based detection found no vulnerabilities on port 53

port 53/tcp

Version-based detection found no vulnerabilities on port 110

port 110/tcp

Version-based detection found no vulnerabilities on port 143

port 143/tcp

Version-based detection found no vulnerabilities on port 443

port 443/tcp

Version-based detection found no vulnerabilities for Exim smtpd 4.98.1

port 587/tcp

Version-based detection found no vulnerabilities on port 993
port 993/tcp

Version-based detection found no vulnerabilities on port 995
port 995/tcp

Version-based detection found no vulnerabilities on port 2077
port 2077/tcp

Version-based detection found no vulnerabilities on port 2078
port 2078/tcp

Version-based detection found no vulnerabilities on port 2079
port 2079/tcp

Version-based detection found no vulnerabilities for TwistedWeb httpd 9.0.0
port 2080/tcp

Version-based detection found no vulnerabilities on port 2083
port 2083/tcp

Version-based detection found no vulnerabilities on port 2096
port 2096/tcp

Scan coverage information

List of tests performed (32/32)

- Running IP information lookup phase
- Performing DNS enumeration
- Performing OS detection
- Running port discovery
- Scanning for publicly exposed File Transfer Protocol (FTP) service
- Checking for web redirect on port 80
- Checking for web redirect on port 2082
- Checking for web redirect on port 2095
- Checking for soft-fail ~all configuration in SPF record
- Attempting zone transfer against name servers...
- Searching for version-based vulnerabilities on port 21
- Searching for version-based vulnerabilities on port 25
- Searching for version-based vulnerabilities on port 26
- Searching for version-based vulnerabilities on port 53
- Searching for version-based vulnerabilities on port 110
- Searching for version-based vulnerabilities on port 143
- Fingerprinting website for technologies on port 443
- Searching for version-based vulnerabilities on port 443
- Searching for version-based vulnerabilities on port 587
- Searching for version-based vulnerabilities on port 993
- Searching for version-based vulnerabilities on port 995
- Fingerprinting website for technologies on port 2077
- Searching for version-based vulnerabilities on port 2077
- Fingerprinting website for technologies on port 2078
- Searching for version-based vulnerabilities on port 2078
- Searching for version-based vulnerabilities on port 2079
- Fingerprinting website for technologies on port 2080

- Searching for version-based vulnerabilities on port 2080
- Fingerprinting website for technologies on port 2083
- Searching for version-based vulnerabilities on port 2083
- Fingerprinting website for technologies on port 2096
- Searching for version-based vulnerabilities on port 2096

Scan parameters

Target:	www.mutualtrustmfb.com
Preset:	Deep
Scanning engines:	Version_based, Sniper, Nuclei
Check alive:	True
Extensive modules:	False
Protocol type:	TCP
Ports to scan:	Top 5000 ports
CVEs:	
Requests per second:	-

SSL/TLS Vulnerability Scanner Report

www.mutualtrustmfb.com

Summary

Overall risk level:
Medium

Risk ratings:

Critical:	0
High:	0
Medium:	1
Low:	0
Info:	34

Scan information:

Start time:	Mar 10, 2025 / 23:11:58 UTC+02
Finish time:	Mar 10, 2025 / 23:59:32 UTC+02
Scan duration:	47 min, 34 sec
Tests performed:	35/35
Scan status:	Finished

Findings

SSL/TLS: BEAST vulnerability found
port 443/tcp

Target is vulnerable but it has support for higher protocols: TLSv1.1, TLSv1.2.

Details

Risk description:
BEAST, short for Browser Exploit Against SSL/TLS is an attack that leverages weaknesses in cipher block chaining (CBC) to exploit the SSL/TLS protocol. The CBC vulnerability can enable man-in-the-middle (MITM) attacks against SSL to silently decrypt and obtain authentication tokens, thereby providing hackers access to data passed between a Web server and the Web browser accessing the server.
The BEAST vulnerability is registered in the NIST NVD database asCVE-2011-3389.

Recommendation:
To mitigate BEAST, it is recommended to require only TLS 1.1+ ciphers for your server and to reduce the lifespan of the SSL session. More details can be found at https://community.pivotal.io/s/article/Mitigation-of-CVE-2011-3389-BEAST-for-web-server-administrators-2008784.

Found 19 open ports, 9 with SSL/TLS support.

Port	State	Service	Server version	Uses SSL/TLS
587	open	smtp	4.98.1	Yes
110	open	pop3		Yes
12005	closed	dbisamserver1		No
443	open	https		Yes
21	open	ftp		Yes
2082	open	infowave		No
465	open	smtp	4.98.1	Yes
2077	open	tsrmagt		No
80	open	http		No
12002	closed	entexthigh		No
993	open	imaps		No

2080	open	https	9.0.0	Yes
995	open	pop3s		No
2078	open	https		Yes
2083	open	radsec		No
2096	open	nbx-dir		No
12001	closed	entextnetwk		No
12009	closed	ghvpn		No
25	open	smtp		No
143	open	imap		Yes
26	open	smtp	4.98.1	Yes
2095	open	nbx-ser		No
2079	open	idware-router		No

SSL/TLS: Certificate is trusted
port 443/tcp

The domain has been found among Subject Alternate Names (SAN) or is the Common Name (CN) itself.
Therefore, it is considered protected by the certificate.

The Server Name Indication (SNI) has also been found. SNI is an extension to the TLS protocol that allows a client or browser to indicate which hostname it is trying to connect to at the start of the TLS handshake.
This allows the server to present multiple certificates on the same IP address and port number.

SSL/TLS: Certificate is Valid
port 443/tcp

The certificate will expire in 116 days.

SSL/TLS: CA Issuer is invalid or it cannot be identified
port 443/tcp

Sectigo rsa domain validation secure server ca (sectigo limited from gb)
Details

Risk description:
The certificate does not have a valid Certificate Authority Issuer, which are important for checking identity of the owner. Having this risk may result in the browsers not being able to validate the server's identity, compromising the communication between the server and users.

Recommendation:
We recommend you to configure a valid Certificate Authority Issuer for your servers's certificates.

Tested for certificate issues.
port 443/tcp

Certificate number: #1
Issuer: Sectigo RSA Domain Validation Secure Server CA (Sectigo Limited from GB)
Signature: SHA256 with RSA
Serial number: E23EECF195B3BC096940989631997B0C

Check SSL certificate error
port 587/tcp

Check SSL certificate error

port 110/tcp

No SSL certificate has been found
port 21/tcp

Check SSL certificate error
port 465/tcp

Check SSL certificate error
port 2080/tcp

Check SSL certificate error
port 2078/tcp

Check SSL certificate error
port 143/tcp

Check SSL certificate error
port 26/tcp

SSL/TLS: Error scanning SSL vulnerabilities
port 587/tcp

SSL/TLS: Error scanning SSL vulnerabilities
port 110/tcp

SSL/TLS: Not vulnerable to Heartbleed
port 443/tcp

SSL/TLS: Not vulnerable to CCS Injection
port 443/tcp

SSL/TLS: Not vulnerable to Ticketbleed
port 443/tcp

SSL/TLS: Not vulnerable to ROBOT
port 443/tcp

SSL/TLS: Not vulnerable to Secure Renegotiation
port 443/tcp

SSL/TLS: Not vulnerable to CRIME
port 443/tcp

SSL/TLS: Not vulnerable to POODLE

port 443/tcp

SSL/TLS: Not vulnerable to SWEET32
port 443/tcp

SSL/TLS: Not vulnerable to FREAK
port 443/tcp

SSL/TLS: Not vulnerable to DROWN
port 443/tcp

SSL/TLS: Not vulnerable to LOGJAM
port 443/tcp

SSL/TLS: Not vulnerable to RC4
port 443/tcp

Tested for SSL/TLS vulnerabilities
port 443/tcp

SSL/TLS: Error scanning SSL vulnerabilities
port 21/tcp

SSL/TLS: Error scanning SSL vulnerabilities
port 465/tcp

SSL/TLS: Error scanning SSL vulnerabilities
port 2080/tcp

SSL/TLS: Error scanning SSL vulnerabilities
port 2078/tcp

SSL/TLS: Error scanning SSL vulnerabilities
port 143/tcp

SSL/TLS: Error scanning SSL vulnerabilities
port 26/tcp

Scan coverage information

List of tests performed (35/35)

- Checking for SSL/TLS services...
- Check SSL certificate error
- Check SSL certificate error
- Checking if the certificate is trusted...
- Checking if the certificate is expired...

- Checking for Certificate Authority Issuer...
- Checking the certificate on port 443...
- No SSL certificate has been found
- Check SSL certificate error
- Check SSL certificate error
- Check SSL certificate error
- Check SSL certificate error
- Check SSL certificate error
- SSL/TLS: Error scanning SSL vulnerabilities
- SSL/TLS: Error scanning SSL vulnerabilities
- Scanning for HEARTBLEED on port 443
- Scanning for CCS on port 443
- Scanning for TICKETBLEED on port 443
- Scanning for ROBOT on port 443
- Scanning for SECURE_RENEGO on port 443
- Scanning for CRIME_TLS on port 443
- Scanning for POODLE_SSL on port 443
- Scanning for SWEET32 on port 443
- Scanning for FREAK on port 443
- Scanning for DROWN on port 443
- Scanning for LOGJAM on port 443
- Scanning for BEAST on port 443
- Scanning for RC4 on port 443
- Tested for SSL/TLS vulnerabilities
- SSL/TLS: Error scanning SSL vulnerabilities
- SSL/TLS: Error scanning SSL vulnerabilities
- SSL/TLS: Error scanning SSL vulnerabilities
- SSL/TLS: Error scanning SSL vulnerabilities
- SSL/TLS: Error scanning SSL vulnerabilities
- SSL/TLS: Error scanning SSL vulnerabilities

Scan parameters

Target:	www.mutualtrustmfb.com
Preset:	Deep
Scanning engines:	Certificate, Vulnerability
Ports to scan:	Top 1000 ports